



المدرسة الوطنية للعلوم التطبيقية - بني ملال

ⵜⴰⵎⴰⵔⵜ ⵜⴰⵎⴰⵏⴰⵢⵜ ⵜⴰⵖⴰⵏⴰⵏⵜ ⵜⴰⵙⴰⵎⴰⵏⴰⵢⵜ - ⵎⴰⵎⴰⵍ ⵔⵉⵎⴰⵏⴰⵢⵜ

Ecole Nationale des Sciences Appliquées - Béni Mellal

NATIONAL SCHOOL OF APPLIED SCIENCES OF BENI MELLAL

Sultan Moulay Slimane University | Program: AI & Cybersecurity

GOVERNANCE FRAMEWORK

Design of a Responsible AI System Compliant with GDPR

Written by	AGOURRAM Hajar BOUARAFA Sara
Supervisor	Pr. TOUIL

Module: *Ethics and Digital Law*

Academic Year: 2025-2026

1. Introduction and Objectives

This document defines the ethical and organisational governance framework for the artificial intelligence system deployed within the École Nationale des Sciences Appliquées de Béni Mellal (ENSA). It constitutes one of the central deliverables of the educational project for the Ethics and Digital Law module.

This governance framework is designed to ensure that the AI system — intended for automated content generation, decision assistance, and non-sensitive data processing — is developed, deployed, and operated in compliance with the fundamental rights of the persons concerned, the requirements of the GDPR, and the ethical principles of trustworthy artificial intelligence.

1.1 Scope of Application

This framework applies to:

- All components of the AI system deployed at ENSA Béni Mellal;
- All actors involved in its development, operation, and use;
- All data processed in the context of the system's operation;
- All decisions made with the assistance of the AI system.

1.2 Governance Objectives

The governance framework pursues six fundamental objectives:

- Ensure permanent compliance of the AI system with GDPR requirements and applicable law;
- Ensure effective and documented human oversight of all AI-assisted decisions;
- Promote transparency towards users and all stakeholders;
- Clearly assign responsibilities to each actor in the value chain;
- Establish robust mechanisms for control, audit, and continuous improvement;
- Prevent and effectively address ethical, legal, and technical risks.

2. Governance Structure: Organisational Chart

The governance of the ENSA AI system rests on a five-level architecture, articulating strategic, operational, functional, technical, and usage responsibilities. This structure ensures complete coverage of the accountability obligations defined by Article 5.2 of the GDPR.

Level	Body	Composition	Mission
Strategic	ENSA Management	Director of the institution	Final decision, AI policy approval, public compliance commitment
Operational	AI Supervision Committee	DPO + Pedagogical Manager + Technical Referent	Steering, quarterly review, incident management, change validation
Functional	DPO	Designated Data Protection Officer	GDPR compliance, DPIA, data subjects' rights, CNDP liaison
Technical	Technical Team / Processor	Developers, system administrators	Deployment, security, maintenance, logging
Usage	End Users	ENSA students and staff	Responsible use, anomaly reporting, exercise of rights

2.1 Identification and Roles of Actors

Each actor in the AI system is assigned precise and unambiguous responsibilities, in accordance with the provisions of the GDPR and AI governance principles. The table below details these assignments:

Actor	Designation	Primary Role	GDPR Obligations
Data Controller	ENSA Béni Mellal Management	Defines purposes and means of processing; assumes global responsibility for the AI system	Art. 5, 24, 25, 30, 35 GDPR
Technical Processor	Host / infrastructure provider	Provides secure hosting, availability, and technical maintenance of the system	Art. 28 GDPR – Mandatory contract

Data Protection Officer (DPO)	Designated by ENSA Management	Legal advice, compliance control, CNDP contact point, DPIA management	Art. 37-39 GDPR
AI Supervision Committee	DPO + Pedagogical Manager + Technical Referent	Quarterly system review, drift detection, change validation	Art. 35 GDPR – DPIA review
End User	ENSA students and academic/administrative staff	Uses the system in compliance with the usage policy; responsible for submitted queries	Subject of rights Art. 13-22 GDPR

2.2 Responsibility Matrix

The matrix below establishes, for each key responsibility of the system, the primary and secondary actor involved, as well as the applicable regulatory reference:

Responsibility	Primary Actor	Secondary Actor	Reference
Definition of processing purposes	Data Controller	DPO	Art. 5 & 6 GDPR
Conducting and updating the DPIA	DPO	AI Supervision Committee	Art. 35 GDPR
Technical security of the system	Technical Processor	Data Controller	Art. 32 GDPR
User training and awareness	DPO	Pedagogical Management	Art. 5.2 GDPR
Human validation of academic decisions	Pedagogical Manager	AI Supervision Committee	Art. 22 GDPR
Processing of rights exercise requests	DPO	Data Controller	Art. 12-22 GDPR
Periodic governance review	AI Supervision Committee	DPO	Art. 24 GDPR
Notification in case of data breach	Data Controller	DPO	Art. 33 GDPR

3. Human Oversight Mechanisms

Human oversight is the central pillar of the ethical governance of the AI system. In accordance with Article 22 of the GDPR and the principles of trustworthy AI defined by the European Commission in its Ethics Guidelines for Trustworthy AI (2019), the system guarantees effective human control over all decisions likely to significantly affect the persons concerned.

3.1 Two Distinct Oversight Regimes

The system distinguishes two application regimes for Article 22 GDPR according to the nature and impact of the decision:

Regime	Type of decision	Circuit	Art. 22 GDPR
Regime 1	Simple assistance responses (summaries, explanations, educational questions)	Transmitted directly to the user with mandatory warning about the automatic nature of the response	Not applicable – no significant legal effect
Regime 2	Decisions with academic impact (evaluations, guidance, results, sanctions)	1) AI suggestion generated 2) Mandatory human validation (authorised supervisor) 3) Communication to the data subject	Fully applicable – human validation BEFORE communication

3.2 Human Validation Circuit (Regime 2)

For any decision with academic impact, the following validation circuit is mandatory and must be documented in the traceability log:

- Step 1: Generation – The AI system generates a suggestion or recommendation, automatically recorded in the log with timestamp and pseudonymised identifier;
- Step 2: Human review – An authorised human supervisor examines the suggestion; may validate, modify, or reject it. Their identity and the approval date are recorded;
- Step 3: Communication – Only the decision validated by the human supervisor is communicated to the person concerned. The raw AI suggestion is never transmitted directly.

3.3 Contestation Procedure

Any user has the right to contest a response or a decision assisted by the AI system. The procedure is as follows:

- Submission of a contestation request via the dedicated form or by direct contact with the DPO;
- Acknowledgement of receipt within 48 hours;
- Examination of the contestation by the AI Supervision Committee within 5 working days;
- Notification of the decision rendered, with justification, within 10 working days;
- Possibility of appeal to the ENSA Management in case of persistent disagreement.

3.4 Decision Traceability

Each interaction with the AI system is subject to complete logging including:

- Pseudonymised user identifier;
- Precise timestamp (date, time, timezone);
- Nature of the request (functional category);
- Response status (simple assistance / submitted for validation);
- Identity and validation date of the human supervisor (for Regime 2);
- Final result communicated to the user.

4. Transparency Requirements

Transparency is a fundamental right of the persons affected by the AI system, enshrined in Articles 13 and 14 of the GDPR. It is also at the heart of the principles of trustworthy AI defined by the European Commission. This framework defines five levels of transparency requirements:

Transparency Requirement	Implementation modality	Reference
Prior information before use	Clear and accessible notice indicating the use of an AI system, its capabilities and limitations, displayed before any first interaction	Art. 13 GDPR + Transparency principle
Systematic warning on each response	Standard message displayed on all responses: "This response was automatically generated by an AI system. Human validation is recommended for any important decision."	Art. 22 GDPR + EU Trustworthy AI Principles
Explanation of general operation	Accessible technical documentation explaining in non-technical terms how the system generates its responses and what data it uses	Art. 13 §2.f GDPR
Documentation of limitations and risks	Public register of inappropriate use cases, error risks (hallucinations), and domains where AI responses must be systematically verified	EU Trustworthy AI Principles 2019
Annual governance report	Publication of an annual report on system use, incidents detected, rights exercised, and improvements made	Art. 5.2 GDPR: Accountability

4.1 Mandatory Content of the Information Notice (Art. 13 GDPR)

The information notice displayed before any use of the system must contain at minimum the following elements:

- Identity and contact details of the data controller (ENSA Béni Mellal);
- DPO contact details and contact modalities;
- Purposes and legal basis for processing (Art. 6.1.e GDPR: public interest mission);
- Nature of data collected and retention period;
- Data subjects' rights and exercise modalities;
- Existence of automated processing and its implications;
- Explicit prohibition on entering personal or sensitive data.

5. Audit and Control Mechanisms

The governance framework provides a set of periodic control mechanisms guaranteeing the continuous compliance of the AI system and the improvement of its governance. These mechanisms concretely translate the accountability principle of Article 5.2 of the GDPR.

Control Mechanism	Frequency	Responsible	Expected deliverables
DPIA Review	Annual	DPO + AI Supervision Committee	Updated and signed DPIA
GDPR Compliance Audit	Annual	DPO	Audit report and remediation plan
Log and access review	Quarterly	Technical Manager	Access dashboard and detected anomalies
Usage policy review	Annual	DPO + Management	Updated policy redistributed to users
Security test (pentest)	Annual	Technical Processor	Test report and applied fixes
User satisfaction assessment	Semi-annual	Pedagogical Management	Survey results and improvement plan
Supervision committee review	Quarterly	AI Supervision Committee	Meeting minutes and decisions recorded

5.1 Role of the AI Supervision Committee

The AI Supervision Committee is the central control body of the system. It meets quarterly and its missions are:

- Examine the performance and compliance indicators of the system;
- Analyse incidents and anomalies detected since the last meeting;
- Validate the functional and technical changes to the system;
- Decide on corrective measures in case of identified drift;
- Propose updates to this governance framework;
- Produce minutes of each meeting, archived and accessible to the DPO.

5.2 Key Compliance Indicators (KPIs)

The following indicators are measured and reported quarterly by the AI Supervision Committee:

- Human validation rate of Regime 2 decisions (target: 100%);
- Average processing time for rights exercise requests (target: < 30 days);
- Number of security incidents or data breaches detected;
- User satisfaction rate with the system and its operation;
- Number of contestations received and average processing time;
- User training coverage (target: 100% before first access).

6. Incident and Data Breach Management

In accordance with Articles 33 and 34 of the GDPR, the governance framework provides a formalised procedure for managing security incidents and personal data breaches. This procedure must be known to all actors involved.

Phase	Action	Responsible	Deadline	Reference
Detection	Identification of the incident (breach, anomaly, malfunction)	User / Technical Manager	Immediate	Art. 33 GDPR
Assessment	Qualification of severity and impact on persons concerned	DPO	< 24h	Art. 33 GDPR
Notification	Notification to CNDP if risk to rights and freedoms	Data Controller + DPO	< 72h	Art. 33 GDPR
Containment	Isolation of the failing system or functionality	Technical Manager	< 4h	Art. 32 GDPR
Information	Informing persons concerned if high risk	DPO	Without delay	Art. 34 GDPR
Remediation	Correction, restoration, and verification of the system	Processor + Manager	< 72h	Art. 32 GDPR
Post-incident	Incident report, root cause analysis, DPIA update	DPO + AI Supervision Committee	< 30 days	Art. 35 GDPR

6.1 Definition of Incidents

The following constitute incidents subject to this procedure:

- Any personal data breach (unauthorised access, disclosure, loss, destruction);
- Any malfunction of the AI system producing incorrect or discriminatory responses;
- Any attempt to enter or process sensitive data within the meaning of Article 9 GDPR;
- Any unauthorised access to the system or its logs;

- Any automated decision transmitted without human validation in violation of Regime 2.

6.2 Incident Register

An incident register is maintained by the DPO. It records for each incident: the date and time of detection, the nature and extent of the incident, the persons concerned, the measures taken, and lessons learned. This register is reviewed at each AI Supervision Committee meeting.

7. Review and Update of the Governance Framework

7.1 Review Frequency

This governance framework is subject to mandatory review in the following cases:

- Systematic annual review, led by the DPO and validated by the Management;
- Exceptional review in case of substantial modification of the AI system or its purposes;
- Exceptional review in case of regulatory change impacting the processing (new regulation, CNDP decision);
- Exceptional review after any major security incident or data breach.

7.2 Validation Process

Any revision of the governance framework follows this process:

- Proposal of modifications by the DPO or the AI Supervision Committee;
- Consultation with representative users and relevant stakeholders;
- Validation by the AI Supervision Committee;
- Final approval by the ENSA Management;
- Distribution of the new version to all concerned actors and publication on the dedicated document space.

7.3 Revision History

Version	Date	Changes	Author
1.0	2025-2026	Initial version: creation of the governance framework as part of the EDN educational project	Project Team

8. Conclusion

This governance framework defines a comprehensive and structured mechanism to ensure the responsible, transparent, and compliant deployment of the ENSA Béni Mellal AI system. It covers all dimensions required by the GDPR and the ethical principles of trustworthy AI: identification of actors and their responsibilities, differentiated human oversight according to the impact of decisions, transparency requirements, audit mechanisms, and incident management procedures.

This framework is not a static document: it constitutes a living commitment, subject to regular revision, that must evolve with the AI system and the regulatory context. Its effective implementation rests on the commitment of all identified actors, from Management to end users, in respect of the rights of the persons concerned and the general interest of the ENSA community.

9. Regulatory References

- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 (GDPR);
- Ethics Guidelines for Trustworthy AI, European Commission, High-Level Expert Group on AI, 2019;
- EDPB Guidelines on Impact Assessment (DPIA) – WP248;
- Proposal for a Regulation on Artificial Intelligence (AI Act), European Commission, 2021;
- Recommendation CM/Rec(2020)1 of the Committee of Ministers of the Council of Europe;
- Guidelines 04/2022 of the EDPB on the calculation of administrative fines (Art. 83 GDPR).